SPIKA TECH™

# NORMA DE GESTIÓN DE VULNERABILIDADES TÉCNICAS

| HISTORIAL DEL DOCUMENTO | | | |
|---|---|---|---|
| **Versión** | **Resumen de modificaciones** | **Fecha de entrada** | **Sustituye a (Código, revisión)** |
| 01 | Primera versión del documento. | 26/02/2025 | N/A |

| REGISTRO DE FIRMAS | | | |
|---|---|---|---|
| **Función:** | **Elaborado por:** | **Revisado por:** | **Aprobado por:** |
| Departamento: | Responsable del SGSI | Dirección | Jefe de seguridad (o suplente) |
| Nombre: | David Pozo | Carlos Rodrigo | Carlos Zúñiga |
| Firma: | Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025 | Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025 | Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un |
| Fecha: | 26/02/2025 | 26/02/2025 | 26/02/2025 |

## CONTENIDO


1 OBJETIVO ..... 4
2 ALCANCE ..... 4
3 DESCRIPCIÓN ..... 4
3.1 PLANES DE MANTENIMIENTO ..... 4
3.1.1 MANTENIMIENTO PERIÓDICO ..... 4
3.1.2 PLAN ANUAL DE MANTENIMIENTO ..... 5
3.1.3 PERSONAL DE MANTENIMIENTO ..... 5
3.2 MANTENIMIENTO DE SISTEMAS ..... 6
3.2.1 ACTUALIZACIÓN DE SISTEMAS ..... 6
3.2.2 CONTROL DE DISPONIBILIDAD ..... 7
3.2.3 TAREAS PROGRAMADAS ..... 7
3.3 MANTENIMIENTO DEL PUESTO DE TRABAJO ..... 7
3.3.1 CONTROL DE SOFTWARE DAÑINO ..... 8
3.3.2 ACTUALIZACIONES DEL SISTEMA OPERATIVO ..... 8
3.3.3 OTRAS OPERACIONES DE MANTENIMIENTO ..... 9
3.4 MANTENIMIENTO DE BASE DE DATOS ..... 9
3.5 SOPORTES DE INFORMACIÓN ..... 10
4 ANEXO I: PLANIFICACIÓN DE GESTIÓN DE VULNERABILIDADES ..... 11
5 REFERENCIAS ..... 12

# 1 OBJETIVO

El objeto del presente documento es la definición de las normas para el mantenimiento y gestión diaria de los Sistemas de Información de SPIKA TECH, garantizando de esta forma que la gestión de los equipos críticos para la prestación de los servicios es adecuada a los requisitos de seguridad de SPIKA TECH y minimizando las amenazas sobre los mismos.

# 2 ALCANCE

Esta norma contempla en su alcance la totalidad de los Sistemas de Información existentes en SPIKA TECH y a cualquier recurso tecnológico asociado. Por otra parte, será de aplicación por todos los profesionales responsables de la gestión del mantenimiento de los sistemas integrados en los servicios que presta SPIKA TECH, ya sean sistemas propios o externos.

# 3 DESCRIPCIÓN

El mantenimiento se define como la conservación de un elemento en buen uso o estado. El mantenimiento puede ser:

- Mantenimiento predictivo: aquel que se establece en base al análisis de parámetros de servicio en un activo, con objeto de predecir posibles averías o funcionamientos erróneos del mismo.
- Mantenimiento preventivo: consiste en la realización de tareas de conservación destinadas a la prevención de averías en los sistemas de información.

## 3.1 PLANES DE MANTENIMIENTO

### 3.1.1 MANTENIMIENTO PERIÓDICO

Todos los activos críticos que estén determinados así en el inventario y que prestan un servicio deberán ser monitorizados permanentemente, lo que permitirá detectar en tiempo real diferentes problemas relacionados con su mantenimiento y generar una incidencia en el sistema de gestión de incidencias.

Adicionalmente, los sistemas que son parte de los servicios que ofrece SPIKA TECH (servidores, switches, firewalls, etc.), tendrán un plan de revisión periódica de acuerdo con las

recomendaciones de cada fabricante, además de estar redundados, lo que garantizará su mantenimiento óptimo para la operación habitual de estos activos.

### 3.1.2 PLAN ANUAL DE MANTENIMIENTO

El responsable del área de ciberseguridad SPIKA TECH elaborará un Plan anual de mantenimiento a ejecutar por el equipo TIC de sistemas o el proveedor de dicho contrato.

El Plan anual de mantenimiento se apoyará en la información técnica recopilada a lo largo del año anterior en el registro de incidencias, así como en cualquier otro documento en el que se reflejen las tareas de operación efectuadas, y contendrá una descripción con el nivel de detalle adecuado, de las tareas preventivas y predictivas a realizar por el área de sistemas durante el año en que se emite.

Si una vez aprobado el Plan Anual de Mantenimiento fuera necesario introducir cambios en el mismo, éstos serán coordinados por el responsable del área de sistemas que aprueba la solicitud de cambio y modifica el Plan Anual de Mantenimiento para incluir la nueva versión.

### 3.1.3 PERSONAL DE MANTENIMIENTO

Sólo el personal interno autorizado para el mantenimiento, así como el personal autorizado de las empresas que lo ofrecen en cada caso, pueden realizar las tareas de reparaciones y el mantenimiento de los equipos, sistemas o aplicaciones.

Las incidencias derivadas del Plan Anual de Mantenimiento, tanto las de carácter preventivo como las predictivas, se plasman en el sistema de gestión de incidencias para que el personal de Sistemas proceda a su ejecución en los plazos estimados.

Las incidencias pueden asignarse al área en su conjunto o a técnicos concretos dentro de la misma, así como a proveedores externos, en función de su naturaleza o complejidad.

La duración real de la tarea, así como cualquier información relevante de su ejecución y los estados por los que ha pasado, quedan reflejados en el registro de incidencias, hecho que permitirá su trazabilidad y control.

## 3.2 MANTENIMIENTO DE SISTEMAS

### 3.2.1 ACTUALIZACIÓN DE SISTEMAS

Se monitorizarán los sistemas de forma continua, permitiendo así que el área de sistemas disponga de la información adecuada para detectar si hay necesidad de realizar actualizaciones en los sistemas. En caso afirmativo el responsable del sistema procederá a gestionar y planificar dichas actualizaciones teniendo en cuenta los siguientes tiempos:

| Categoría de la actualización | Tiempo máximo de instalación |
|---|---|
| Actualizaciones de características | 730 días (2 años) |
| Actualizaciones de calidad | 365 días (1 año) |
| Actualizaciones de seguridad | 90 días |
| Actualizaciones de seguridad críticas | 30 días |

- Las **actualizaciones de características** son consideradas aquellas actualizaciones que incluyen mejoras y nuevas funcionalidades en el sistema operativo.
- Las **actualizaciones de calidad** buscan mejorar la fiabilidad del sistema operativo, y no incluyen nuevas características ni funcionalidades nuevas.
- Las **actualizaciones de seguridad** corrigen vulnerabilidades que pueden suponer un riesgo potencial para SPIKA TECH.
- Las **Actualizaciones de seguridad críticas**, son aquellas que tienen una puntuación mayor o igual a 9 usando la valoración CVSS (Common Vulnerability Score System), o son categorizadas como “Críticas” o “Muy críticas” por el proveedor o alguna entidad de reconocido prestigio.

Para el resto del hardware, (router, firewall, switch, ...), se consultará semanalmente, por parte del área de sistemas, la existencia de parches, actualizaciones de sistemas operativo, software, firmware, etc...

Independientemente de esta revisión periódica, será posible la solicitud de revisiones extraordinarias ante la posible presencia de vulnerabilidades no corregidas, detectadas a través de la realización de análisis de vulnerabilidades.

Las actualizaciones críticas de seguridad en los sistemas de SPIKA TECH siempre se considerarán muy importantes y, por tanto, su prioridad será máxima. Por todo esto, dichas actualizaciones deberán ser autorizadas por parte del responsable de ciberseguridad.

En cualquier caso, previo al despliegue de cualquier actualización, se deberán realizar pruebas en sistemas especialmente habilitados para ello y que no estén en entornos productivos, garantizando así la compatibilidad de las nuevas actualizaciones con los servicios ya proporcionados por SPIKA TECH.

### 3.2.2 CONTROL DE DISPONIBILIDAD

Se controlará la disponibilidad de los recursos corporativos de SPIKA TECH, generando incidencias en el sistema de gestión de incidencias, a la atención del área de sistemas, ante cualquier degradación en la misma o ante cualquier elemento que pueda ser síntoma de una degradación futura. Esta información podrá ser consultada para la realización de informes, o determinar la calidad del servicio de los recursos de SPIKA TECH.

En caso de que los niveles de calidad no sean satisfactorios para la prestación de los servicios por parte de SPIKA TECH, el responsable del área de IT propondrá las medidas correctivas para recuperar la calidad del servicio.

### 3.2.3 TAREAS PROGRAMADAS

Cualquier parada por motivos de mantenimiento que pueda perjudicar a los sistemas de información, será notificada a las personas de contacto de los diferentes servicios que puedan verse afectados por la misma. Dicha parada se realiza de forma obligatoria en horario de baja actividad.

Todas las paradas quedarán reflejadas en el sistema de gestión de incidencias, ya sea de forma manual o mediante una tarea programada.

## 3.3 MANTENIMIENTO DEL PUESTO DE TRABAJO

Todos los puestos de trabajo de SPIKA TECH con acceso a internet, están directamente sometidos a los siguientes riesgos:

- Malware.

- Vulnerabilidades en los sistemas operativos y/o aplicaciones.

Para salvaguardar la seguridad de los puestos de trabajo, se han establecido las siguientes acciones.

### 3.3.1 CONTROL DE SOFTWARE DAÑINO

Con el objeto de prevenir la entrada de software dañino, todos los puestos de trabajo propiedad de SPIKA TECH, dispondrán de manera obligatoria de al menos un sistema de detección de malware.

### 3.3.2 ACTUALIZACIONES DEL SISTEMA OPERATIVO

En los puestos de trabajo se configurarán las actualizaciones del sistema operativo y parches de seguridad instalándose a través de las herramientas habilitadas en SPIKA TECH.

La instalación se realizará de manera escalonada, permitiendo garantizar así que no interrumpe la operativa normal de trabajo de los usuarios, cumpliendo los plazos indicados en la siguiente tabla:

| Categoría de la actualización | Tiempo máximo de instalación |
|---|---|
| Actualizaciones de características | 730 días (2 años) |
| Actualizaciones de calidad | 365 días (1 año) |
| Actualizaciones de seguridad | 90 días |
| Actualizaciones de seguridad críticas | 30 días |

- Las **actualizaciones de características** son consideradas aquellas actualizaciones que incluyen mejoras y nuevas funcionalidades en el sistema operativo.
- Las **actualizaciones de calidad** buscan mejorar la fiabilidad del sistema operativo, y no incluyen nuevas características ni funcionalidades nuevas.
- Las **actualizaciones de seguridad** corrigen vulnerabilidades que pueden suponer un riesgo potencial para SPIKA TECH.
- Las **Actualizaciones de seguridad críticas**, son aquellas que tienen una puntuación mayor o igual a 9 usando la valoración CVSS (Common Vulnerability Score System),

o son categorizadas como “Críticas” o “Muy críticas” por el proveedor o alguna entidad de reconocido prestigio.

### 3.3.3 OTRAS OPERACIONES DE MANTENIMIENTO

Además de las indicadas, se recomienda realizar las siguientes tareas periódicas de mantenimiento en los puestos de trabajo:

- Desfragmentación del disco o discos duros.
- Revisión del espacio de almacenamiento disponible.
- Revisión de la existencia de software no corporativo instalado. Este tipo de instalaciones deben ser oportunamente aprobadas por la dirección y en caso de no estar registrado, se aconseja su eliminación por considerarse una posible amenaza.
- Compactación de las carpetas del gestor de correo electrónico.
- Validar la seguridad de las conexiones remotas: VPN, 4G, etc.

## 3.4 MANTENIMIENTO DE BASE DE DATOS

Entre las tareas de mantenimiento específicas de las bases de datos se encuentran las siguientes:

- Revisión de los sistemas de alertas (logs) de las bases de datos, en el que se registran los principales eventos ocurridos, así como los accesos, permitiendo detectar anomalías en el funcionamiento de la base de datos y en los intentos de acceso no autorizado a la misma.
- Revisión de la actividad de las tablas de las bases de datos.
- Reconstrucción de índices de la base de datos, para evitar la merma en el rendimiento.
- Borrado de tablas temporales que ya no sean necesarias.
- Revisión del almacenamiento de las bases de datos (tablespace).
- Liberar espacio en tablespace de marcha atrás.
- Liberar espacio en los sistemas de archivos.
- Desconexión de sesiones que no se estén utilizando, con el objeto de liberar recursos innecesarios.

## 3.5 SOPORTES DE INFORMACIÓN

SPIKA TECH entiende como soporte de información a todo dispositivo que nos permite almacenar información en formato electrónico y que en general, es fácil de transportar, tales como DVD, pendrives, discos duros extraíbles...

El responsable de cada soporte corporativo debe realizar un plan de mantenimiento acorde a las recomendaciones de cada fabricante, así mismo, deberá contar con medidas para preservar la información física almacenada en estos.

# 4 ANEXO I: PLANIFICACIÓN DE GESTIÓN DE VULNERABILIDADES

## 1. INFORMACIÓN GENERAL

| PARÁMETRO | DETALLE |
|---|---|
| Fecha del análisis | |
| Sistema analizado | |
| Responsable | |
| Herramienta | |

## 2. RESUMEN DE VULNERABILIDADES TÉCNICAS

| ID | VULNERABILIDAD | SEVERIDAD | IMPACTO POTENCIAL | PRIORIDAD |
|---|---|---|---|---|
| | | | | |
| | | | | |

## 3. PLAN DE ACCIÓN

| ID | ACCIÓN CORRECTIVA | RESPONSABLE | PLAZO | ESTADO |
|---|---|---|---|---|
| | | | | |
| | | | | |

# 5 REFERENCIAS

- ISO/ IEC 27001:2022:
    - 8.8 Gestión de Vulnerabilidades técnicas.
    - 8.9 Gestión de la configuración.
- 8.21 Seguridad de los servicios de red.
- 7.13 Mantenimiento de equipos.